

Politique de sécurité des systèmes d'information

PSSI — règles de sécurité applicables à tous

Référence	NTG-SMSI-PSSI-001
Version	1.0 du 27 septembre 2026
Classification	Interne
Propriétaire	RSSI
Approbateur	Direction générale (CEO)
Statut	Approuvé
Exigences couvertes	ISO/IEC 27001:2022, article 5.2 et article 7.5.1 b) ; annexe A, mesure 5.1

Document de démonstration. NotAge est une entreprise fictive, créée pour un projet de portfolio en gouvernance de la sécurité. Toute ressemblance avec une entreprise existante serait fortuite.

Maîtrise du document

Version	Date	Auteur	Objet de la version
0.1	20/09/2026	RSSI	Projet soumis au comité de sécurité
1.0	27/09/2026	RSSI	Version approuvée par la direction générale ; intègre les mesures du plan de traitement des risques

Diffusion : tous les salariés, stagiaires et prestataires de NotAge. La PSSI peut être communiquée aux clients et aux auditeurs sur demande, sous engagement de confidentialité. **Prochaine revue** : septembre 2027 au plus tard.

Documents de référence

Référence	Document
NTG-SMSI-POL-001	Politique du SMSI
NTG-SMSI-GOV-001	Organisation de la sécurité et matrice RACI
NTG-SMSI-CTX-003 / 004	Périmètre du SMSI ; cartographie et inventaire des actifs
NTG-SMSI-RSK-003 / 004	Rapport d'analyse de risques ; plan de traitement des risques
NTG-SMSI-DDA-001	Déclaration d'applicabilité
NTG-SMSI-PRC-001 / 002	Procédures de gestion des incidents et de gestion des accès

Sommaire

1. Objet, domaine d'application et principes.....	3
2. Organisation de la sécurité.....	4
3. Gestion des actifs et classification de l'information.....	4
4. Ressources humaines et sensibilisation.....	5
5. Contrôle d'accès et authentification.....	6
6. Postes de travail, mobilité et locaux.....	7
7. Infrastructure cloud et exploitation.....	7
8. Développement sécurisé et gestion des changements.....	8
9. Relations avec les fournisseurs.....	9
10. Gestion des incidents de sécurité.....	9
11. Continuité d'activité.....	10
12. Conformité, protection des données et contrôle.....	10
Approbation.....	11
Annexe — Correspondance entre scénarios de risque et règles.....	12

1. Objet, domaine d'application et principes

La présente PSSI décline la politique du SMSI (NTG-SMSI-POL-001) en règles concrètes, applicables par toutes et tous. Elle s'appuie sur l'appréciation des risques de septembre 2026 (NTG-SMSI-RSK-003) et sur la déclaration d'applicabilité (NTG-SMSI-DDA-001).

Elle s'applique au périmètre du SMSI (NTG-SMSI-CTX-003) : à tous les salariés, stagiaires et prestataires de NotAge, à l'ensemble de son système d'information, et à tous les lieux de travail (bureaux de Paris, télétravail, déplacements).

La sécurité de l'information chez NotAge repose sur six principes :

- **Proportionnalité** : chaque règle répond à un risque, à une exigence légale ou à un engagement contractuel.
- **Moindre privilège et besoin d'en connaître** : chacun n'accède qu'à ce dont il a besoin pour sa mission.
- **Défense en profondeur** : aucune mesure ne suffit seule ; les protections se complètent.
- **Sécurité dès la conception** : la sécurité est prise en compte au début des projets, pas à la fin.
- **Traçabilité** : toute action sensible est journalisée et attribuable à une personne.
- **Responsabilité de chacun** : la sécurité n'est pas l'affaire de la seule RSSI.

Dans les règles ci-dessous, « doit » exprime une obligation. Chaque règle porte un identifiant (par exemple ACC-04) et renvoie aux mesures de l'annexe A d'ISO/IEC 27001:2022 qu'elle met en œuvre.

Définitions utilisées dans la PSSI

Terme	Définition
Donnée client	Toute donnée confiée par un client ou par ses utilisateurs : identités, IBAN, justificatifs, données comptables.
Compte à privilèges	Compte qui permet d'administrer un système ou d'accéder à des données en masse (AWS, GitHub, console d'administration).
Authentification multifacteur	Preuve d'identité qui combine au moins deux facteurs : mot de passe et code, ou clé de sécurité physique.
Authentification unique (SSO)	Connexion unique qui donne accès aux outils de l'entreprise avec une seule identité maîtrisée.
Événement de sécurité	Situation qui pourrait signaler une atteinte à la sécurité : e-mail suspect, alerte technique, appareil perdu.
Incident de sécurité	Événement qui porte, ou risque de porter, atteinte à la disponibilité, à l'intégrité ou à la confidentialité de l'information.
Violation de données	Incident qui entraîne la perte, l'altération, la divulgation ou l'accès non autorisé à des données personnelles (au sens du RGPD).
RTO et RPO	Durée maximale d'interruption admissible (RTO) et perte de données maximale admissible (RPO) après un incident.
Dérogation	Autorisation écrite, justifiée et limitée dans le temps de ne pas appliquer une règle.

Règle	Exigence	Annexe A
GEN-01	La PSSI est obligatoire pour toute personne ayant accès au système d'information de NotAge. Son non-respect peut entraîner des sanctions, conformément au règlement intérieur et aux contrats.	5.1, 5.4, 6.4
GEN-02	Toute dérogation à une règle doit être demandée par écrit à la RSSI, justifiée par une analyse de risque, validée par le propriétaire du risque et limitée à six mois au plus. Les dérogations sont inscrites dans un registre revu en comité de sécurité.	5.36

2. Organisation de la sécurité

Les rôles, le comité de sécurité et la matrice RACI sont détaillés dans le document NTG-SMSI-GOV-001. Cette section en rappelle les règles essentielles.

Règle	Exigence	Annexe A
ORG-01	La direction générale approuve la PSSI, alloue les ressources nécessaires à la sécurité et accepte les risques résiduels élevés.	5.4
ORG-02	La RSSI, rattachée à la direction générale, pilote le SMSI, anime le comité de sécurité, tient à jour la PSSI et conseille les propriétaires des risques.	5.2
ORG-03	Chaque actif et chaque risque a un propriétaire désigné, inscrit dans l'inventaire des actifs et dans le registre des risques.	5.2, 5.9
ORG-04	Les tâches sensibles sont séparées : nul ne peut à la fois demander, valider et réaliser un changement en production, et la RSSI n'administre pas la production.	5.3
ORG-05	La RSSI entretient les contacts avec les autorités (CNIL, ANSSI et CERT-FR, forces de l'ordre en cas de fraude) et avec des groupes spécialisés (alertes du CERT-FR, club de RSSI).	5.5, 5.6
ORG-06	La RSSI assure une veille sur les menaces visant les éditeurs SaaS et la fraude au virement, et en tient compte dans l'appréciation des risques.	5.7

Qui fait quoi

Acteur	Responsabilités au titre de la PSSI
Chaque collaborateur	Applique la PSSI, protège ses accès et ses appareils, suit la sensibilisation, signale sans délai tout événement suspect.
Managers	Valident les droits d'accès de leur équipe, participent aux revues trimestrielles, veillent au suivi de la sensibilisation.
Propriétaires d'actifs	Protègent l'actif au quotidien, valident les accès, participent à l'appréciation des risques qui le concernent.
Propriétaires de risques	Décident du traitement de leurs risques, pilotent les actions du plan de traitement, acceptent le risque résiduel.
RSSI	Pilote le SMSI, conseille, contrôle l'application de la PSSI, coordonne la gestion des incidents.
Direction générale	Approuve la PSSI, alloue les ressources, arbitre les priorités, accepte les risques résiduels élevés.

3. Gestion des actifs et classification de l'information

On ne protège bien que ce que l'on connaît. Les actifs sont inventoriés, et chaque information est classée pour savoir comment la manipuler.

Règle	Exigence	Annexe A
ACT-01	L'inventaire des actifs (NTG-SMSI-CTX-004) est tenu à jour par la RSSI avec les propriétaires. Il est revu chaque année et à chaque adoption d'un nouvel outil.	5.9
ACT-02	Toute information est classée selon quatre niveaux : Public, Interne, Confidentiel, Strictement confidentiel. À défaut de marquage, elle est traitée comme Interne ; les données des clients sont Confidentielles par défaut.	5.12
ACT-03	La classification figure dans l'en-tête de chaque document. Les règles de manipulation du tableau ci-dessous s'appliquent à chaque niveau.	5.13

Règle	Exigence	Annexe A
ACT-04	Les échanges de données avec les clients passent uniquement par la plateforme ou par des API authentifiées et chiffrées. Aucune donnée client ne transite par une messagerie personnelle, une clé USB ou un service de partage non autorisé.	5.14
ACT-05	Aucune donnée de production (IBAN, justificatifs) ne doit être copiée dans un ticket, un message Slack ou un document de travail : on utilise l'identifiant du dossier.	5.14, 8.12

Règles de manipulation selon la classification

Niveau	Stockage	Partage interne	Envoi à l'extérieur	Destruction
Public	Libre	Libre	Libre	Aucune précaution
Interne	Outils de l'entreprise	Salariés et prestataires sous contrat	Avec l'accord du propriétaire	Suppression standard
Confidentiel	Espaces à accès nominatif	Selon le besoin d'en connaître	Canal chiffré ou lien à accès restreint	Suppression sécurisée, destructeur pour le papier
Strictement confidentiel	Coffre dédié, accès journalisé	Liste nominative validée par le propriétaire	Interdit, sauf accord de la RSSI	Effacement certifié

4. Ressources humaines et sensibilisation

La plupart des attaques commencent par une personne : un mot de passe réutilisé, un e-mail piégé, un appareil perdu. Cette section encadre le cycle de vie des collaborateurs et leur sensibilisation.

Règle	Exigence	Annexe A
RH-01	Avant l'embauche, les références et les diplômes sont vérifiés. Des vérifications renforcées sont menées pour les postes à privilèges, dans le respect du droit du travail.	6.1
RH-02	Les contrats de travail et de prestation contiennent une clause de confidentialité et l'obligation de respecter la PSSI. Les prestataires et stagiaires signent un engagement de confidentialité avant tout accès.	6.2, 6.6
RH-03	Chaque nouvel arrivant suit une sensibilisation (PSSI, hameçonnage, signalement, classification) avant l'ouverture de ses accès aux données des clients.	6.3
RH-04	Tous les salariés suivent une sensibilisation annuelle. Une campagne d'hameçonnage simulé a lieu chaque trimestre ; les personnes piégées reçoivent un module complémentaire, sans sanction.	6.3
RH-05	Des formations spécifiques complètent la sensibilisation : codage sécurisé pour les développeurs (annuelle), gestion des incidents pour l'équipe infrastructure, détection de la fraude au virement pour le support.	6.3
RH-06	Au départ ou au changement de poste, la procédure NTG-SMSI-PRC-002 s'applique : retrait des accès, restitution du matériel, rappel écrit des obligations de confidentialité qui perdurent après le contrat.	5.11, 6.5

Plan de sensibilisation et de formation

Public	Fréquence	Contenu	Indicateur
Tous les salariés	Arrivée, puis chaque année	Règles essentielles, hameçonnage, signalement, classification	100 % sensibilisés chaque année
Tous les salariés	Chaque trimestre	Hameçonnage simulé	Taux de clic et taux de signalement
Développeurs	Chaque année	Codage sécurisé (OWASP), gestion des secrets	100 % formés
Support client	Chaque année	Fraude au changement d'IBAN, ingénierie sociale	100 % formés
Infrastructure	Chaque année	Réponse aux incidents, exercice de crise	Exercice réalisé

5. Contrôle d'accès et authentification

Les identités et les privilèges sont la première cause racine des risques de NotAge (R02, R05, R06, R07). Les règles opérationnelles détaillées figurent dans la procédure NTG-SMSI-PRC-002.

Règle	Exigence	Annexe A
ACC-01	Les accès sont attribués selon le besoin d'en connaître et le moindre privilège, par profils prédéfinis, et validés par le manager et par le propriétaire de l'actif.	5.15, 5.18
ACC-02	Chaque personne dispose d'une identité unique et nominative. Les comptes partagés sont interdits ; les comptes de service sont documentés et ont un propriétaire.	5.16
ACC-03	Tous les outils de l'entreprise sont raccordés à l'authentification unique (SSO) lorsque c'est techniquement possible. Les exceptions sont recensées et revues chaque trimestre.	5.16
ACC-04	L'authentification multifacteur est obligatoire pour tous les salariés, sur tous les outils. Les comptes à privilèges (AWS, GitHub, administration Google) utilisent des clés de sécurité physiques, résistantes à l'hameçonnage.	8.5
ACC-05	Sur la plateforme, l'authentification multifacteur est obligatoire pour les rôles administrateur et valideur des clients. Une réauthentification est exigée avant toute action sensible : modification d'IBAN, ajout d'utilisateur, export massif.	8.5, 8.26
ACC-06	Les mots de passe comptent au moins 12 caractères (une phrase de passe est recommandée), sont uniques pour chaque service et stockés dans le gestionnaire fourni. Aucun renouvellement périodique n'est imposé, mais tout mot de passe est changé immédiatement en cas de suspicion de compromission.	5.17
ACC-07	Les secrets techniques (clés d'API, mots de passe de bases de données) sont stockés dans un coffre dédié, jamais dans le code ni dans un message. Ils sont renouvelés au moins une fois par an, et immédiatement en cas d'exposition.	5.17
ACC-08	Deux administrateurs permanents au plus disposent de droits étendus sur AWS. Les autres obtiennent une élévation temporaire, sur demande tracée, limitée à 8 heures. Aucune clé d'accès AWS de longue durée n'est autorisée.	8.2, 8.18
ACC-09	Les droits d'accès sont revus chaque trimestre par les managers et les propriétaires des actifs ; les droits non justifiés sont retirés sous 5 jours ouvrés.	5.18
ACC-10	Le support n'accède qu'aux comptes des clients ayant ouvert une demande, pour la durée de son traitement. Les IBAN y sont masqués (4 derniers caractères visibles). Les consultations sont journalisées et revues chaque mois par échantillonnage.	8.3, 8.11, 8.15

6. Postes de travail, mobilité et locaux

Les salariés de NotAge travaillent au bureau, chez eux et en déplacement. Les règles suivantes protègent les appareils et les lieux, quel que soit l'endroit.

Règle	Exigence	Annexe A
POS-01	Seuls les ordinateurs fournis et gérés par NotAge peuvent accéder aux données des clients et à la production. Ils sont gérés centralement : chiffrement du disque, mises à jour automatiques, protection contre les logiciels malveillants, effacement à distance.	8.1, 8.7
POS-02	Les smartphones personnels n'accèdent à la messagerie et à Slack que par un profil professionnel protégé (code de verrouillage, chiffrement, effacement du profil à distance). Aucune donnée client n'y est stockée.	8.1
POS-03	Les logiciels sont installés depuis le catalogue validé. Les droits d'administration locaux sont réservés aux personnes qui en ont besoin. Le filtrage web bloque les sites malveillants.	8.1, 8.23
POS-04	La charte d'utilisation des moyens informatiques, annexée au règlement intérieur, est signée à l'arrivée : usage professionnel, usage personnel raisonnable toléré, interdits.	5.10
POS-05	Les sessions se verrouillent automatiquement après 5 minutes d'inactivité et doivent être verrouillées dès que l'on s'éloigne. Aucun document Confidentiel ne reste sur un bureau ; les impressions sont récupérées immédiatement.	7.7
POS-06	En télétravail et en déplacement : réseau domestique protégé ou partage de connexion du téléphone (jamais de Wi-Fi public en direct), conversations confidentielles hors de portée d'oreille, filtre de confidentialité dans les transports.	6.7, 7.9
POS-07	Toute perte ou tout vol d'appareil est déclaré à l'informatique interne dans les 24 heures, et si possible dans l'heure, pour déclencher l'effacement à distance.	6.8, 7.9
POS-08	Les supports amovibles sont déconseillés. Lorsqu'ils sont indispensables, ils sont fournis par NotAge et chiffrés.	7.10
POS-09	Les bureaux sont accessibles par badge nominatif ; les visiteurs sont enregistrés et accompagnés ; les locaux sont fermés à clé en dehors des heures ouvrées ; l'équipement réseau est dans une baie fermée. L'immeuble est équipé d'une alarme et d'une vidéosurveillance.	7.1, 7.2, 7.3, 7.4, 7.8
POS-10	Avant maintenance, réattribution ou recyclage, les données sont sauvegardées puis effacées ; l'effacement est certifié avant tout recyclage.	7.13, 7.14

7. Infrastructure cloud et exploitation

La plateforme est entièrement hébergée sur AWS. NotAge est responsable de la sécurité de ce qu'elle déploie et configure dans le cloud ; AWS l'est de l'infrastructure physique (modèle de responsabilité partagée).

Règle	Exigence	Annexe A
EXP-01	Seuls les services AWS autorisés sont utilisés. La production, les environnements hors production, les sauvegardes et les journaux sont dans des comptes AWS distincts. Les données des clients restent dans la région de Paris ; les sauvegardes sont copiées dans une autre région de l'Union européenne.	5.23, 8.22
EXP-02	L'infrastructure est décrite en code et suit des configurations de référence (accès public bloqué, chiffrement et journalisation activés). Toute modification passe par une revue. Un contrôle automatique continu signale toute dérive.	8.9

Règle	Exigence	Annexe A
EXP-03	Les bases de données et les services internes ne sont jamais exposés à Internet. Le trafic entrant passe uniquement par le répartiteur de charge, le pare-feu applicatif et la protection contre le déni de service.	8.20, 8.21
EXP-04	Les données sont chiffrées en transit (TLS 1.2 au minimum) et au repos. Les clés sont gérées par le service de gestion de clés d'AWS ; leur usage est restreint et journalisé.	8.24
EXP-05	Les vulnérabilités sont corrigées dans les délais suivants : critique, 15 jours ; élevée, 30 jours ; moyenne, 90 jours. Tout dépassement est accepté par écrit par le propriétaire du risque. Un test d'intrusion est réalisé chaque année.	8.8
EXP-06	La base de données est sauvegardée en continu (perte d'une heure au plus). Des copies quotidiennes chiffrées et immuables sont conservées 35 jours dans un compte séparé. Une restauration est testée chaque trimestre et documentée.	8.13
EXP-07	Les journaux applicatifs (connexions, modifications de coordonnées bancaires, exports, actions d'administration) et d'infrastructure sont centralisés, protégés contre la modification et conservés un an. Les horloges sont synchronisées sur une source de référence.	8.15, 8.17
EXP-08	Des alertes signalent les événements sensibles : suppression de sauvegardes, modification des droits, exposition publique d'une ressource, connexion inhabituelle suivie d'un changement d'IBAN. Elles sont traitées selon la procédure NTG-SMSI-PRC-001.	8.16
EXP-09	Les exports massifs de données et la présence d'IBAN dans les tickets ou les messages sont détectés et signalés.	8.12
EXP-10	La plateforme s'adapte automatiquement à la charge. La capacité est suivie, et testée avant les périodes de clôture.	8.6
EXP-11	Les procédures d'exploitation (déploiement, sauvegarde, restauration, renouvellement des secrets) sont documentées et accessibles à l'équipe d'astreinte.	5.37

8. Développement sécurisé et gestion des changements

NotAge développe elle-même sa plateforme. La sécurité applicative non outillée est l'une des cinq causes racines de ses risques (R01, R03, R05).

Règle	Exigence	Annexe A
DEV-01	Toute fonctionnalité touchant aux paiements, à l'authentification ou aux données personnelles fait l'objet d'une analyse de sécurité avant son développement (menaces, exigences), validée par la RSSI.	5.8, 8.25, 8.27
DEV-02	Toute modification d'IBAN exige la validation de deux utilisateurs distincts du client et déclenche une notification au fournisseur concerné et à l'administrateur du client. Le cloisonnement des données entre clients est vérifié à chaque requête.	8.26, 8.27
DEV-03	Le code respecte les règles de codage sécurisé de NotAge, fondées sur les recommandations de l'OWASP. Les dépendances proviennent de sources fiables ; les actions tierces de la chaîne CI/CD sont figées sur une version vérifiée.	8.28
DEV-04	L'accès à GitHub se fait par SSO et authentification multifacteur, selon le besoin. La branche principale est protégée : aucune modification directe, revue obligatoire par une autre personne, tests réussis.	5.3, 8.4
DEV-05	Chaque demande de fusion déclenche une analyse automatique du code, des dépendances et des secrets. Une vulnérabilité critique bloque la fusion.	8.29
DEV-06	Tout changement en production passe par la chaîne CI/CD, après revue, avec un plan de retour arrière et un déploiement progressif. Aucune installation manuelle n'est faite en production.	8.19, 8.32

Règle	Exigence	Annexe A
DEV-07	Les mises en production majeures sont gelées pendant les clôtures (du dernier jour ouvré du mois au troisième jour ouvré du mois suivant), sauf correctif urgent validé par le CTO.	8.32
DEV-08	Production et recette sont dans des comptes AWS distincts. Les développeurs n'ont pas d'accès permanent à la production. Aucune donnée de production n'est utilisée en test sans anonymisation.	8.31, 8.33
DEV-09	Les tests d'intrusion et d'audit sont encadrés par une convention, autorisés par le CTO et planifiés hors des périodes de clôture.	8.34

9. Relations avec les fournisseurs

NotAge dépend de fournisseurs qui hébergent ou traitent les données de ses clients. Elle en reste responsable vis-à-vis de ces derniers, en particulier des clients financiers soumis à DORA.

Règle	Exigence	Annexe A
FOU-01	Les fournisseurs sont classés en trois niveaux. Sont critiques ceux qui accèdent aux données des clients ou sont indispensables au service : AWS, GitHub, Google Workspace, l'outil de support, le service d'envoi d'e-mails transactionnels. Le registre des fournisseurs est tenu par le CFO et la RSSI.	5.19
FOU-02	Avant de contracter avec un fournisseur critique, NotAge évalue sa sécurité : certifications (ISO/IEC 27001, SOC 2), questionnaire, localisation des données, sous-traitants.	5.19, 5.21
FOU-03	Les contrats des fournisseurs critiques comprennent au minimum : obligations de sécurité, notification des incidents sous 48 heures, localisation des données dans l'Union européenne, droit d'audit ou remise de rapports d'audit, encadrement de la sous-traitance, réversibilité et suppression des données en fin de contrat, accord de sous-traitance RGPD.	5.20
FOU-04	Les fournisseurs critiques sont revus chaque année : validité des certifications, incidents survenus, changements de service.	5.22
FOU-05	Les services cloud sont configurés selon la section 7. Une stratégie de sortie d'AWS est documentée et revue chaque année.	5.23
FOU-06	Les composants logiciels tiers (bibliothèques, actions CI/CD) sont inventoriés et leurs mises à jour suivies.	5.21
FOU-07	NotAge respecte les engagements pris envers ses clients financiers au titre de DORA : notification des incidents, droit d'audit, localisation des données, continuité, réversibilité.	5.20, 5.31

10. Gestion des incidents de sécurité

Détecter vite et réagir de façon organisée limite les conséquences d'un incident. Le déroulé complet, la grille de gravité et les fiches réflexes figurent dans la procédure NTG-SMSI-PRC-001.

Règle	Exigence	Annexe A
INC-01	Tout salarié signale sans délai tout événement suspect (e-mail douteux, appareil perdu, comportement anormal, erreur d'envoi) via le canal unique : bouton de signalement de la messagerie ou canal Slack #securite. La RSSI accuse réception dans l'heure ouvrée.	6.8
INC-02	Un signalement de bonne foi n'entraîne jamais de sanction, même lorsqu'il porte sur une erreur de son auteur.	6.8

Règle	Exigence	Annexe A
INC-03	Chaque événement est qualifié selon la grille de gravité de la procédure (P1 à P4). Une astreinte est assurée jour et nuit par l'équipe infrastructure ; une cellule de crise est réunie pour tout incident P1.	5.24, 5.25
INC-04	Les clients concernés sont informés dans les 24 heures suivant la qualification d'un incident majeur ou d'une violation de leurs données, sauf délai contractuel plus court. NotAge notifie la CNIL sous 72 heures pour ses propres traitements, prévient son assureur et, si NIS2 lui devient applicable, l'ANSSI.	5.5, 5.26
INC-05	Les preuves (journaux, copies) sont conservées intactes ; aucune action destructrice n'est engagée avant leur copie. Une plainte est déposée en cas de fraude.	5.28
INC-06	Tout incident P1 ou P2 donne lieu à un retour d'expérience sous 15 jours. Les actions correctives sont suivies en comité de sécurité. La RSSI tient le registre des incidents.	5.27

11. Continuité d'activité

Les clients utilisent NotAge pour leurs clôtures comptables mensuelles : une interruption à ce moment a des conséquences directes (R08). La continuité couvre aussi le risque climatique retenu dans l'analyse du contexte.

Règle	Exigence	Annexe A
CON-01	Les objectifs de reprise de la plateforme sont les suivants : reprise en 4 heures au plus (RTO), perte de données d'une heure au plus (RPO).	5.30
CON-02	La plateforme est répartie sur au moins deux zones de disponibilité AWS ; les sauvegardes sont copiées dans une autre région de l'Union européenne.	8.14
CON-03	Un plan de reprise documenté couvre la perte d'une zone, la perte de la région, le rançongiciel et la corruption de données. Il est testé chaque année ; les résultats sont présentés en revue de direction.	5.30
CON-04	En mode dégradé, les mesures de sécurité restent en vigueur (authentification, journalisation, cloisonnement). Toute dérogation temporaire est validée par la RSSI et tracée.	5.29
CON-05	En cas d'indisponibilité des bureaux (crue, canicule, sinistre), l'activité bascule en télétravail complet ; aucun service critique ne dépend des locaux.	7.5, 7.11
CON-06	Les rôles critiques (administration AWS, déploiement) sont documentés et disposent d'un suppléant formé.	5.30

12. Conformité, protection des données et contrôle

NotAge doit respecter le RGPD, ses engagements contractuels et, le cas échéant, NIS2. Cette section fixe aussi la façon dont l'application de la PSSI est contrôlée.

Règle	Exigence	Annexe A
CNF-01	Les exigences légales, réglementaires et contractuelles sont recensées (NTG-SMSI-CTX-002) et suivies par une veille assurée par la RSSI et le DPO.	5.31
CNF-02	Un DPO est désigné. NotAge tient le registre de ses traitements, signe un accord de sous-traitance (article 28 du RGPD) avec chaque client, applique la minimisation des données et mène une analyse d'impact pour tout traitement à risque.	5.34
CNF-03	À la fin d'un contrat, les données du client lui sont restituées puis supprimées sous 90 jours ; les sauvegardes sont effacées à l'expiration de leur cycle. Un certificat de suppression est fourni sur demande.	8.10

Règle	Exigence	Annexe A
CNF-04	Les licences logicielles sont suivies ; seuls les composants open source dont la licence est compatible avec l'offre de NotAge sont utilisés.	5.32
CNF-05	Les enregistrements du SMSI sont protégés et conservés au moins trois ans, les journaux un an, sauf obligation plus longue.	5.33
CNF-06	L'application de la PSSI est contrôlée par les managers et la RSSI, suivie par des indicateurs en comité de sécurité, et vérifiée chaque année par un audit interne confié à un prestataire externe.	5.35, 5.36
CNF-07	La PSSI est revue au moins une fois par an, ainsi qu'après tout incident majeur, tout changement significatif ou toute évolution réglementaire (entrée en vigueur de NIS2, par exemple).	5.1

Approbation

La présente PSSI a été présentée au comité de sécurité puis approuvée par la direction générale. Elle entre en vigueur à sa date d'approbation et est portée à la connaissance de chaque collaborateur.

Rédigée par La RSSI Date : 27/09/2026 Visa	Approuvée par Le directeur général (CEO) Date : 27/09/2026 Visa
--	---

Annexe — Correspondance entre scénarios de risque et règles

Chaque scénario du registre des risques (NTG-SMSI-RSK-002) est traité par des règles de la présente PSSI. Le niveau de risque est indiqué avant traitement puis après, tel que visé par le plan de traitement (NTG-SMSI-RSK-004).

Risque	Scénario	Niveau	Règles de la PSSI
R01	Fraude au changement d'IBAN fournisseur	12 → 4	ACC-05, DEV-02, EXP-07, EXP-08, RH-05
R02	Rançongiciel après compromission d'un compte administrateur AWS	12 → 6	ACC-04, ACC-08, ACC-09, EXP-06, EXP-08, INC-03, CON-03
R03	Vol de données via une vulnérabilité applicative	12 → 8	DEV-01, DEV-03, DEV-05, EXP-05, RH-05
R04	Exposition de justificatifs par erreur de configuration cloud	8 → 4	EXP-01, EXP-02, EXP-08
R05	Code malveillant ou vol de secrets via la chaîne de développement	8 → 4	ACC-07, DEV-03, DEV-04, DEV-06
R06	Accès abusif du support aux données clients	6 → 3	ACC-10, RH-02, RH-05
R07	Compte d'un ancien salarié resté actif	9 → 3	ACC-02, ACC-03, ACC-09, RH-06
R08	Interruption prolongée en période de clôture	9 → 4	CON-01, CON-02, CON-03, EXP-06, DEV-06, DEV-07
R09	Hameçonnage ciblé d'un compte de messagerie	6 → 4	RH-03, RH-04, ACC-04, INC-01
R10	Perte ou vol d'un portable ou d'un smartphone	6 → 3	POS-01, POS-02, POS-06, POS-07
R11	Fuite via un fournisseur SaaS compromis	6 → 3	FOU-01, FOU-02, FOU-03, FOU-04, ACT-05
R12	Accès d'une autorité étrangère via l'hébergeur (risque accepté)	3 → 3	EXP-01, EXP-04, FOU-05